

PROPOSAL AND SOFTWARE REQUIREMENTS AND DESIGN DOCUMENT

# Hadia Gifting Registry

A warmer way to gift. Wishlists, item reservations and M-Pesa cash gifting for weddings, baby showers, new homes and graduations in Kenya and East Africa.

|                    |                                                                                                   |
|--------------------|---------------------------------------------------------------------------------------------------|
| Prepared for       | Tracey, founder, Hadia                                                                            |
| Prepared by        | Codevertex Africa Limited, <a href="http://www.codevertexafrica.com">www.codevertexafrica.com</a> |
| Document reference | CVX-HADIA-SRDD-001                                                                                |
| Version and date   | 1.0, 6 October 2026                                                                               |
| Delivery window    | 12 weeks (3 months) from signing                                                                  |
| Build cost         | USD 4,750 fixed, inside the USD 1,500 to 5,000 range in the brief                                 |
| Classification     | Confidential. Prepared for Hadia's evaluation only.                                               |

# Document control

| Version | Date       | Author                    | Change                        |
|---------|------------|---------------------------|-------------------------------|
| 1.0     | 6 Oct 2026 | Codevertex Africa Limited | First issue for client review |

| Role           | Name                    | Responsibility                                                   |
|----------------|-------------------------|------------------------------------------------------------------|
| Client sponsor | Tracey (Hadia)          | Scope approval, business decisions, legal sign-off, pilot events |
| Delivery lead  | Codevertex project lead | Plan, scope control, weekly reporting, risk log                  |
| Technical lead | Codevertex engineering  | Architecture, code quality, security, releases                   |

## Contents

|                                          |                                                           |
|------------------------------------------|-----------------------------------------------------------|
| 1. Executive summary                     | 13. Reports and analytics built for growth                |
| 2. What Hadia asked for                  | 14. Security design                                       |
| 3. Benchmark: MyRegistry and Zola        | 15. Legal, regulatory and compliance                      |
| 4. Scope                                 | 16. Delivery methodology                                  |
| 5. Users and roles                       | 17. Implementation timeline                               |
| 6. Functional requirements               | 18. Testing and acceptance                                |
| 7. Non-functional requirements           | 19. Commercials                                           |
| 8. Solution architecture                 | 20. Risks and mitigations                                 |
| 9. Money, escrow and automated payouts   | 21. Assumptions, dependencies and client responsibilities |
| 10. Critical workflows, step by step     | 22. Support after launch                                  |
| 11. Data design                          | 23. Acceptance and sign-off                               |
| 12. Interfaces, events and notifications |                                                           |
| Appendix A: ecosystem audit findings     |                                                           |
| Appendix B: glossary                     |                                                           |

# 1. Executive summary

Hadia is a gift registry for the way Kenyan families already give. A couple, a parent to be or a graduate builds a list of things they would love, shares one link on WhatsApp, and guests either reserve a physical gift so nobody buys the same blender twice, or send money toward a gift or a general fund straight from M-Pesa. Hadia earns a small percentage of cash gifts and an optional one-time premium fee per event.

Codevertex proposes to build Hadia on the Codevertex platform that already runs identity, payments, accounting, escrow and messaging for businesses across our ecosystem. Only the parts that are unique to Hadia are new: the registry itself, the guest experience and the owner dashboard. Everything that touches money reuses services that are already in production and already handle M-Pesa collections, held funds, payouts, double entry books and audit trails.

## The proposal in five lines

- Twelve weeks from signing to a live product with pilot events, including a full week of user acceptance testing.
- USD 4,750 fixed build price, inside the USD 1,500 to 5,000 range in Hadia's brief, paid in four milestones.
- Running costs of about USD 100 to 200 a month, in line with the brief, covered by roughly 100 active events.
- Gift money is held in Hadia's own account with a licensed payment provider (PayHero) and paid out automatically by rules Hadia sets. Codevertex never holds client funds.
- Compliance is designed in from day one: Kenya's Data Protection Act, consumer protection, payments and anti-money laundering rules, accessibility and honest marketing.

The reason a product of this quality fits the budget is reuse. Building phone sign-in, M-Pesa collection, wallet accounting, escrow, approvals, automated payouts, receipts and messaging from scratch would cost several times the brief's upper figure and would take longer than three months. On our platform those pieces exist, are tested with real money, and only need to be configured and connected for Hadia.

## 2. What Hadia asked for

We reviewed the two documents Hadia shared: the Hadia landing page mock-up and the build report prepared for Tracey. The requirements below come straight from them.

### The product, as described

- Phone number and OTP sign-in, because it is more natural than email for this market.
- A wishlist tied to an event with a name, date and type: wedding, baby shower, new home, graduation and birthday.
- Items added by hand (title, description, price estimate, photo) or by pasting a link from any shop, with auto-fill where possible. Manual entry has to be a first-class path because most local retailers publish no clean product data.
- A public link that looks good when pasted into WhatsApp.
- Guests browse, reserve an item so it shows as taken for everyone, or contribute any amount toward an item or a general fund through an M-Pesa STK push.
- An owner dashboard showing reservations and contributions, with payouts to the owner's own M-Pesa, less the platform fee.

### How Hadia makes money

| Stream            | Brief                                                                   | How this design delivers it                                                                                                                                                |
|-------------------|-------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Cash gifting fee  | About 3 to 5% of each contribution, deducted before payout              | A commission rule in Hadia's books (default 4%, editable, with optional minimum and cap) applied automatically at every payout. Guests never pay extra.                    |
| Premium per event | About USD 2 to 3: custom link, printable list, faster or instant payout | A one-time in-app purchase (suggested KSh 300, set by Hadia) that unlocks a custom link, a branded PDF of the list, and instant payouts in place of the standard schedule. |

### What the brief warns about, and our answer

| Concern in the brief                                                                                                                         | Our answer                                                                                                                                                                                                        |
|----------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Holding other people's money brings regulation and trust requirements. Consider a licensed aggregator rather than going direct to Safaricom. | Money is collected and held by PayHero, a payment aggregator, in Hadia's own account. Our treasury service keeps a separate ledger per registry, reconciles hourly, and pays out by rules. See chapters 9 and 15. |
| Daraja approval and business registration take time.                                                                                         | A business and legal track runs in parallel from week one (chapter 17). PayHero onboarding replaces a direct Daraja application, which removes the slowest dependency.                                            |
| Link auto-fill will be unreliable on local sites.                                                                                            | Auto-fill is a helper only. The manual form is the main path and works on a slow phone (chapter 10).                                                                                                              |
| Early payment bugs would damage word of mouth.                                                                                               | The payment core is not new code. It is our production escrow module, with idempotent contributions, one release in flight per pot, automatic return of failed payouts and hourly reconciliation.                 |
| Keep money logic separate from everything else.                                                                                              | It is a separate service. hadia-api never moves money; it asks treasury-api to, and listens for the result.                                                                                                       |

### 3. Benchmark: MyRegistry and Zola

Hadia named MyRegistry and Zola as references. Both are mature US products. We studied their public feature sets and help pages to decide what Hadia should copy, adapt for Kenya, or leave out.

| Capability                                | MyRegistry                                         | Zola                                                                                                | Hadia decision                                                                                                                           |
|-------------------------------------------|----------------------------------------------------|-----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| Add items from any shop                   | Yes, universal registry, browser button and import | Yes, alongside its own store                                                                        | <b>Adopt.</b> Paste a link or enter by hand. No browser extension in the MVP.                                                            |
| Cash funds                                | Yes, advertised with 0% fund fees                  | Yes, card fee of about 2.5% paid by guest or couple, or a fee-free option through a third-party app | <b>Adapt.</b> M-Pesa first. Guests pay exactly the gift amount. Hadia's fee is taken at payout and shown clearly up front.               |
| Group gifting on one item                 | Yes, on any item                                   | Yes, on any gift or fund                                                                            | <b>Adopt.</b> Any item can be reserved, funded in parts, or both.                                                                        |
| Duplicate prevention                      | Cross-store purchase marking                       | Automatic for Zola store items                                                                      | <b>Adopt.</b> Atomic reservation; the item shows as taken instantly for everyone.                                                        |
| Gift tracker and thank-you list           | Yes                                                | Yes, gift tracker and thank-you manager                                                             | <b>Adopt.</b> Gift log with guest messages, thank-you status and one-tap WhatsApp thank-you.                                             |
| Wedding website and planning tools        | Checklists                                         | Full planning suite                                                                                 | <b>Later.</b> A simple event page with story and date is in scope. A full planning suite is not.                                         |
| Own store, shipping, completion discounts | Retailer partnerships                              | Own store and shipping                                                                              | <b>Leave out.</b> Retailer programmes are largely unavailable in Kenya, as the brief notes. A partner referral field is ready for later. |
| Payout timing                             | Depends on fund provider                           | Scheduled transfers                                                                                 | <b>Adapt.</b> Automatic payouts by threshold and event date; instant payouts for premium events.                                         |

Sources consulted on 6 October 2026: MyRegistry guides on universal registries and its Wikipedia entry; Zola's registry page and help articles on group gifting and cash fund fees. Competitor features change often and are listed only to guide product decisions.

Two lessons shape Hadia's positioning. First, fee transparency is a selling point: both benchmarks talk about fees prominently, so Hadia will state its fee in plain words on the guest page and in the owner's settings. Second, the strongest registries make the guest's job effortless. For Hadia that means no account, no app download, and an M-Pesa prompt within two taps of opening the link.

## 4. Scope

### In scope for the 12-week build

| Area             | Included                                                                                                                                             |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| Public website   | Landing page based on the mock-up, how it works, occasions, help centre, legal pages, cookie notice                                                  |
| Owner app (PWA)  | Phone OTP sign-up, events, items, sharing, gift log, thank-you list, payout settings, premium upgrade, data and privacy settings                     |
| Guest experience | Registry page, reserve, contribute by M-Pesa (Airtel Money and card through the same checkout where enabled), receipts, cancel a reservation         |
| Money            | One escrow pot per registry, automatic payouts by rules, commission, commission sweep to Hadia's account, refunds, reconciliation, books in treasury |
| Hadia admin      | Registries, users, reports, approvals, exceptions, fee and limit settings, content moderation, data requests                                         |
| Messaging        | SMS and WhatsApp receipts and alerts, email where an address is given, owner opt-in for marketing                                                    |
| Compliance       | Privacy, terms, refund and cookie policies (drafts for Hadia's advocate), consent records, data export and deletion, accessibility to WCAG 2.2 AA    |

### Out of scope (can be quoted separately)

- Native iOS and Android store apps. The PWA installs to the home screen and covers the MVP.
- A full wedding planning suite, guest RSVP management and seating plans.
- Physical gift delivery, shipping or a Hadia shop.
- Retailer affiliate integrations and price tracking.
- Formal legal opinions. We prepare drafts and a compliance map; Hadia's Kenyan advocate signs them off.
- Paid advertising, video production and influencer campaigns from the go-to-market plan.

## 5. Users and roles

| Role                | Who                                                         | Can do                                                                                                  | Signs in with                                                                 |
|---------------------|-------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| Guest               | Family, friends, diaspora relatives, colleagues             | View a shared registry, reserve, contribute, leave a message, cancel own reservation                    | No account. Phone OTP only when reserving, so the reservation can be managed. |
| Registry owner      | Couple, parent, graduate, family host. Must be 18 or older. | Create and manage events and items, share, see gifts, thank guests, set payout destination, buy premium | Phone and OTP (auth-api), optional Google sign-in                             |
| Co-owner            | Partner or family member invited by the owner               | Edit items and thank guests. Cannot change the payout destination.                                      | Phone and OTP                                                                 |
| Hadia support       | Hadia staff                                                 | Help users, moderate content, view registries, handle data requests                                     | Codevertex SSO with MFA                                                       |
| Hadia finance       | Hadia staff                                                 | Approve payouts above the limit, view books, run reports, manage fees and limits                        | Codevertex SSO with MFA, OTP on each approval                                 |
| Hadia administrator | Tracey and delegates                                        | Everything above, plus staff roles and settings                                                         | Codevertex SSO with MFA                                                       |

Staff permissions use the platform's existing role model (JWT claims plus service-level roles), so Hadia's staff get one login for the Hadia admin console and for treasury-ui, where the books, escrow pots and approvals live.

## 6. Functional requirements

Priorities use MoSCoW: **M** must have for launch, **S** should have for launch, **C** could have if time allows. Each requirement is traced to a workflow in chapter 10 and to an acceptance test.

| ID                           | Requirement                                                                                                                                                                                                   | Pri. |
|------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| Accounts and onboarding      |                                                                                                                                                                                                               |      |
| FR-01                        | Owners sign up and sign in with a phone number and a one-time code sent by SMS, with WhatsApp as a fallback channel. Codes expire in 5 minutes and sending is rate limited.                                   | M    |
| FR-02                        | Owners confirm they are 18 or older and accept the terms and privacy notice. The version and time are stored.                                                                                                 | M    |
| FR-03                        | Owners verify the M-Pesa number that will receive payouts with an OTP sent to that number. The registered M-Pesa name returned on the first payout is compared with the owner's name and flagged on mismatch. | M    |
| FR-04                        | Owners can invite a co-owner by phone. Co-owners cannot change payout details.                                                                                                                                | S    |
| Registries and items         |                                                                                                                                                                                                               |      |
| FR-05                        | Create an event registry with type, title, date, location (optional), cover photo and short story. One owner can hold several registries.                                                                     | M    |
| FR-06                        | Add items by hand: title, description, price, quantity, photo, shop name, and a mode of reserve, fund or both.                                                                                                | M    |
| FR-07                        | Add items by pasting a link. The server reads the page's public metadata and prefills the form. The owner confirms before saving.                                                                             | S    |
| FR-08                        | Create cash funds (honeymoon fund, baby fund, moving fund) with an optional target.                                                                                                                           | M    |
| FR-09                        | Reorder, edit, hide and archive items. Items with gifts against them cannot be deleted, only archived.                                                                                                        | M    |
| FR-10                        | Registry visibility: public link, unlisted (link only, default), or private with a passcode.                                                                                                                  | S    |
| Sharing and guest experience |                                                                                                                                                                                                               |      |
| FR-11                        | Every registry has a short link with a preview image, title and description that render well in WhatsApp, Facebook and SMS.                                                                                   | M    |
| FR-12                        | Guests see items, what is taken, progress on funds, and the event story, with no account and no app.                                                                                                          | M    |
| FR-13                        | Guests reserve an item. The reservation is atomic, so two guests can never reserve the last unit.                                                                                                             | M    |
| FR-14                        | Guests can cancel their own reservation from a link sent to them.                                                                                                                                             | M    |
| FR-15                        | Owners can choose whether guests see who reserved what. The default hides names from other guests.                                                                                                            | S    |
| Contributions and money      |                                                                                                                                                                                                               |      |
| FR-16                        | Guests contribute any amount within the limits toward an item or a fund using an M-Pesa STK push, with Airtel Money and card on the same checkout where enabled.                                              | M    |
| FR-17                        | The guest pays exactly the amount entered. Hadia's fee is never added on top for guests.                                                                                                                      | M    |
| FR-18                        | When the STK prompt cannot reach the phone, the guest is offered a paybill and account number to pay from the M-Pesa menu.                                                                                    | S    |
| FR-19                        | Guests receive an SMS or WhatsApp receipt. Owners receive a gift alert.                                                                                                                                       | M    |

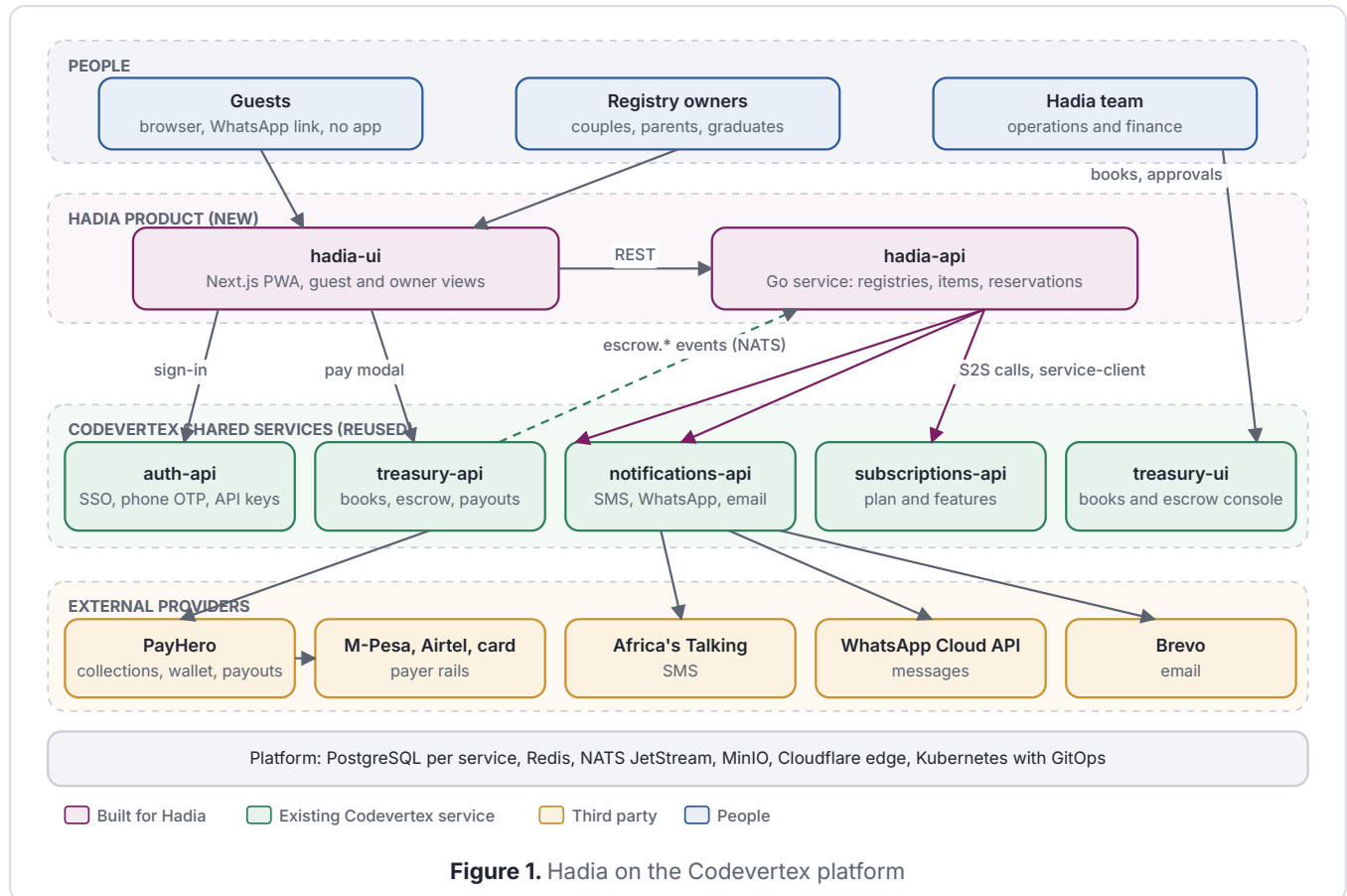
|                             |                                                                                                                                                                                           |          |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| <b>FR-20</b>                | Payouts happen automatically by the registry's rules: when the balance reaches a threshold, on a schedule, and always after the event date. Premium registries can pay out on every gift. | <b>M</b> |
| <b>FR-21</b>                | Hadia's commission is deducted automatically at payout and shown on every payout statement.                                                                                               | <b>M</b> |
| <b>FR-22</b>                | Commission is swept automatically to Hadia's own business account on a schedule, above a minimum amount.                                                                                  | <b>M</b> |
| <b>FR-23</b>                | Payouts above a limit set by Hadia wait for a finance approval with OTP. Everything below goes out without anyone touching it.                                                            | <b>M</b> |
| <b>FR-24</b>                | A cancelled registry refunds each gift to the phone that paid it. Gifts with no phone on record are listed for manual refund.                                                             | <b>M</b> |
| <b>FR-25</b>                | Owners download a statement of gifts and payouts as PDF or spreadsheet.                                                                                                                   | <b>S</b> |
| <b>Owner tools</b>          |                                                                                                                                                                                           |          |
| <b>FR-26</b>                | Gift log with guest name, amount, item and message. Thank-you status with a one-tap WhatsApp thank-you.                                                                                   | <b>M</b> |
| <b>FR-27</b>                | Premium upgrade per event: custom link, printable PDF list, instant payouts. Paid through the same checkout.                                                                              | <b>M</b> |
| <b>FR-28</b>                | Reservation reminders: the owner and the guest are reminded after 14 days if a reserved item is not marked bought. The owner can release it.                                              | <b>C</b> |
| <b>Hadia administration</b> |                                                                                                                                                                                           |          |
| <b>FR-29</b>                | Search registries, owners and gifts. View a registry as a guest sees it.                                                                                                                  | <b>M</b> |
| <b>FR-30</b>                | Set commission, premium price, contribution limits, payout thresholds, approval limit and sweep schedule.                                                                                 | <b>M</b> |
| <b>FR-31</b>                | Exception queue: failed payouts, name mismatches, refunds needing action, reconciliation differences, reported registries.                                                                | <b>M</b> |
| <b>FR-32</b>                | Moderate content: hide a registry or item, record the reason, notify the owner.                                                                                                           | <b>M</b> |
| <b>FR-33</b>                | Reports: gifts and value by day, active events, commission earned, premium sales, conversion from view to gift, payout times.                                                             | <b>M</b> |
| <b>FR-34</b>                | Handle data subject requests: export, correction and deletion, with deadlines tracked.                                                                                                    | <b>M</b> |

## 7. Non-functional requirements

| ID     | Quality               | Target                                                                                                                                                                                                                                    |
|--------|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| NFR-01 | Performance on phones | Guest page under 150 KB of transfer on first load (excluding item photos), Largest Contentful Paint under 2.5 s on a mid-range Android over 3G. Photos served as resized WebP.                                                            |
| NFR-02 | API speed             | 95% of reads under 300 ms and writes under 600 ms at the server, excluding the payment provider's time.                                                                                                                                   |
| NFR-03 | Scale                 | Designed for 10,000 active registries and 2,000 gifts an hour at peak (a busy Saturday) on the current cluster, with no design change needed to grow ten times. Every list is paginated by keyset, every report reads from daily rollups. |
| NFR-04 | Availability          | 99.5% monthly for guest pages and checkout. Two replicas of every service, rolling deploys with no downtime.                                                                                                                              |
| NFR-05 | Money correctness     | Every gift credited exactly once, every payout made at most once, books balanced at all times, hourly reconciliation with the PayHero wallet, zero tolerance for an unexplained difference.                                               |
| NFR-06 | Security              | OWASP ASVS level 2 controls, TLS everywhere, secrets encrypted, MFA for staff, audit trail on every money and settings change.                                                                                                            |
| NFR-07 | Privacy               | Data minimisation, consent records, export and deletion within the Data Protection Act's timelines, personal data hosted in Kenya or in a location covered by a lawful transfer basis.                                                    |
| NFR-08 | Accessibility         | WCAG 2.2 level AA: contrast, keyboard use, focus states, alt text, form labels, screen reader names, text that scales to 200%.                                                                                                            |
| NFR-09 | Languages             | English at launch. Copy kept in translation files so Kiswahili can be added without code changes.                                                                                                                                         |
| NFR-10 | Recoverability        | Daily encrypted backups, point-in-time recovery for the database, recovery point within 24 hours and recovery time within 4 hours.                                                                                                        |
| NFR-11 | Observability         | Structured logs with request IDs, traces across services, alerts on failed payouts, reconciliation differences, error rates and slow pages.                                                                                               |
| NFR-12 | Maintainability       | Same stack and conventions as the rest of the Codevertex fleet, automated tests on every change, documented APIs, no duplicated logic.                                                                                                    |

## 8. Solution architecture

Hadia adds two small applications to the Codevertex platform and reuses five existing services. The diagram shows who talks to whom.



### What is new and what is reused

| Component         | Status                       | Role for Hadia                                                                                                                                                                                                                                 |
|-------------------|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| hadia-ui          | <b>New</b>                   | Next.js progressive web app: landing site, guest registry pages, owner dashboard, Hadia admin console. Uses the shared UI library for the payment modal, sign-in, data tables, legal links and the cookie notice.                              |
| hadia-api         | <b>New</b>                   | Go service owning registries, items, reservations, premium purchases, the gift log projection, daily statistics and consent records. Never moves money.                                                                                        |
| auth-api          | <b>Reused, one addition</b>  | Hadia tenant, staff SSO with MFA, roles, terms acceptance, sessions, developer API keys. <b>Addition:</b> passwordless phone OTP sign-in for consumers (today OTP exists only for signed-in users).                                            |
| treasury-api      | <b>Reused, two additions</b> | Hadia's books, PayHero gateway, the public checkout, escrow pots, approvals, payout dispatcher, reconciliation, statements, eTIMS invoices for Hadia's own fees. <b>Additions:</b> scheduled commission sweep and per-pot contribution limits. |
| treasury-ui       | <b>Reused</b>                | Hadia finance works here: books, escrow pots, approvals, PayHero wallet, reports.                                                                                                                                                              |
| notifications-api | <b>Reused, new templates</b> | SMS through Africa's Talking, WhatsApp, email through Brevo, push. Hadia templates for receipts, alerts, OTPs and reminders.                                                                                                                   |
| subscriptions-api | <b>Reused</b>                | Hadia's platform plan, which switches on the escrow and M-Pesa integration features.                                                                                                                                                           |

|                     |               |                                                                                                                                                                                                         |
|---------------------|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Shared<br>libraries | <b>Reused</b> | shared-auth-client (token checks), shared-service-client (calls with retries and circuit breakers), shared-events (outbox and NATS), cache (Redis and job leases), pagination, httpware, shared-ui-lib. |
|---------------------|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## Design rules we hold to

- **One owner per piece of data.** hadia-api stores treasury's pot ID, never a copy of the balance as truth. Its gift log is a projection rebuilt from treasury events.
- **Money moves in one place.** Only treasury-api talks to PayHero. hadia-api asks and listens.
- **Events first.** Treasury publishes escrow events through its transactional outbox to NATS. hadia-api consumes them idempotently, keyed on the event ID and the payment intent ID.
- **Safe with many replicas.** Scheduled jobs use the shared cache leases so each runs once per period across the fleet. Workers claim rows with conditional updates.
- **Same stack as the fleet.** Go with Ent and Atlas migrations, Next.js with the shared UI library, Helm and ArgoCD for deploys. Any Codevertex engineer can support Hadia.

# 9. Money, escrow and automated payouts

This chapter explains where gift money sits, how it is accounted for, and how payouts and Hadia's fee happen without anyone pressing a button. It is the part of the system that most affects trust, so it is described in more detail than the rest.

## Where the money is

Hadia is a tenant on the Codevertex platform. Hadia gets its own PayHero Team account, in Hadia's name and verified to PayHero's KYC tier 3 with Hadia's company documents. The Team has an isolated wallet that no other tenant and not the platform itself can use; treasury never falls back to another account for a Team tenant. Every guest contribution lands in that wallet. Treasury keeps one sub-ledger (a pot wallet) per registry, so the wallet's balance is always split, to the shilling, between the registries that own it and Hadia's commission.

Codevertex never receives or holds Hadia's or its users' money. PayHero holds it; treasury records it and instructs payouts. Codevertex is paid only for software, through Hadia's subscription.

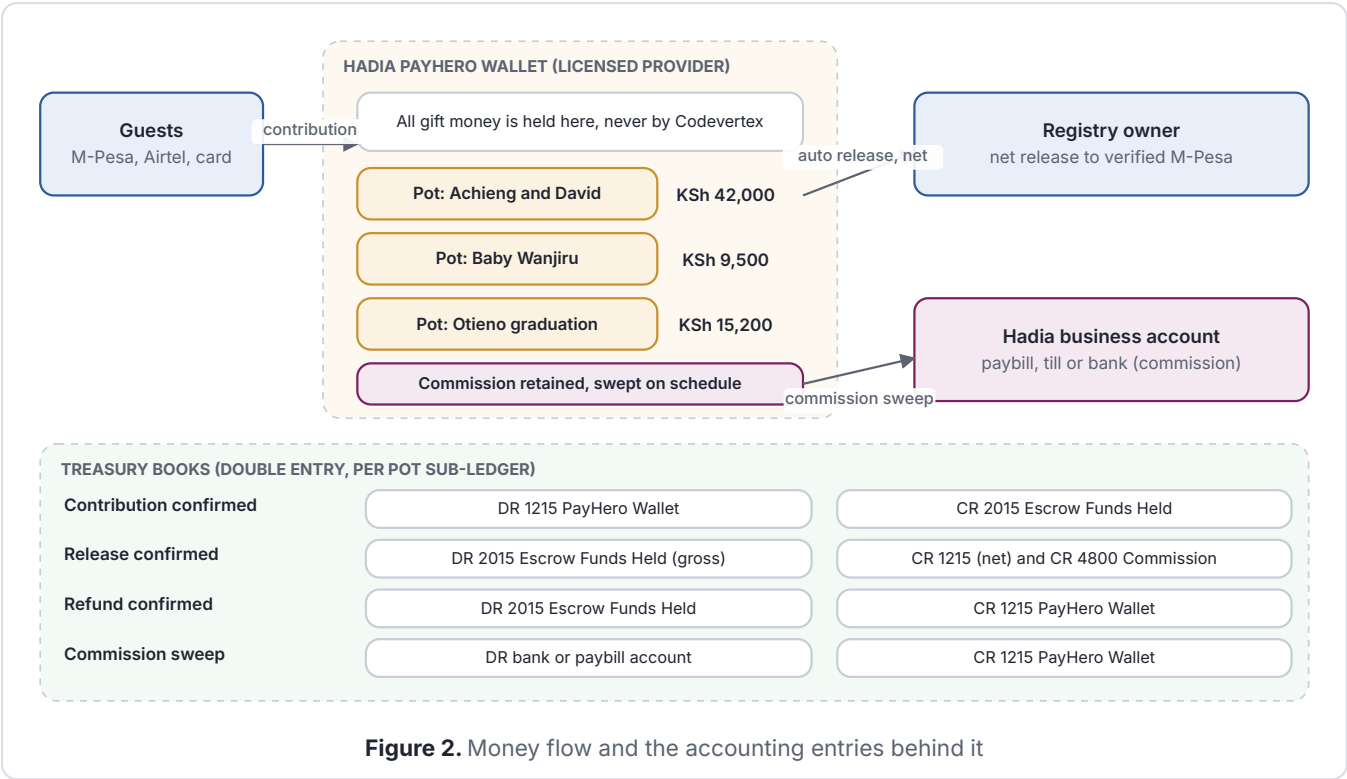
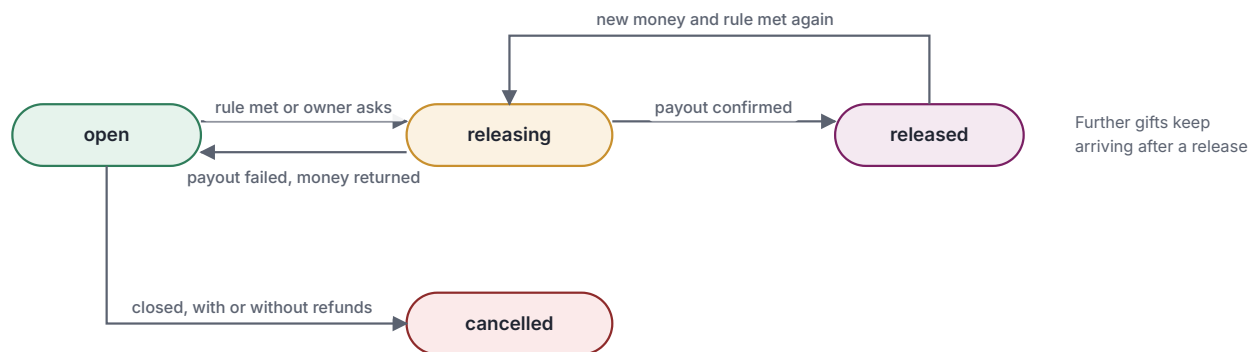


Figure 2. Money flow and the accounting entries behind it

## The pot behind every registry

When an owner's registry goes live, hadia-api asks treasury to open an escrow pot. The pot carries the registry title, the owner as beneficiary (their verified M-Pesa number), the target, the payout rules and the gift items. Pots are created with an external ID equal to the registry ID, so a retry can never open a second pot.



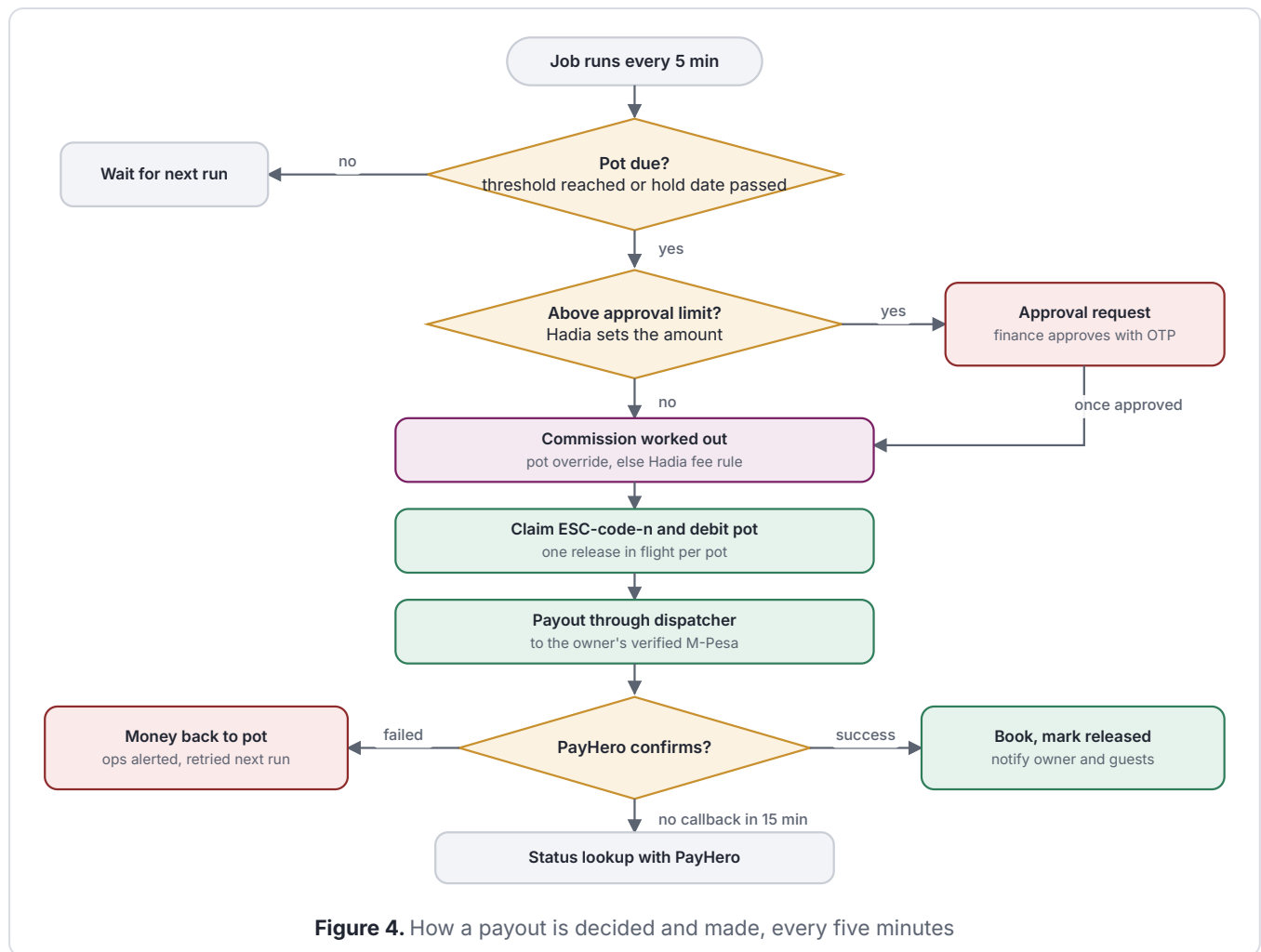
**Figure 3.** Pot lifecycle in treasury

## Payout rules Hadia controls

The client wants payouts to run by thresholds and limits with as little human action as possible. Treasury's escrow module already supports this through each pot's rules and Hadia's payout policy. Hadia sets defaults once; owners can choose within the limits Hadia allows.

| Setting             | Where it lives                                          | Suggested default                                    | Effect                                                                                                                                                       |
|---------------------|---------------------------------------------------------|------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Auto release        | Pot                                                     | On                                                   | The 5-minute job pays out when a rule is met. No one needs to ask.                                                                                           |
| Release threshold   | Pot                                                     | KSh 10,000 standard, KSh 1 premium (pays every gift) | Pays the whole balance once it reaches this amount. Fewer, larger payouts keep M-Pesa costs down.                                                            |
| Hold until          | Pot                                                     | Event date plus 2 days                               | Whatever is left is paid out after the event even if the threshold was never reached.                                                                        |
| Approval limit      | Hadia's escrow release policy (threshold mode)          | KSh 150,000 per payout                               | Payouts at or above it wait for a finance approval with OTP. The approval is bound to the amount and destination, so it cannot be reused for another payout. |
| Commission          | Hadia's escrow fee rule, with optional per-pot override | 4%, no minimum, cap optional                         | Deducted from each payout and booked as Hadia's income.                                                                                                      |
| Contribution limits | Pot (new)                                               | Minimum KSh 50, maximum KSh 150,000 per gift         | Rejects gifts outside the range before the prompt is sent.                                                                                                   |
| Maximum pot balance | Platform cap                                            | Set with Hadia from its risk appetite                | A gift that would take a pot over the cap is refused, which limits exposure and money laundering risk.                                                       |
| Longest hold        | Platform cap                                            | 180 days                                             | Money cannot be held indefinitely.                                                                                                                           |
| Commission handling | Hadia settings (new)                                    | Sweep daily above KSh 5,000, keep KSh 2,000 reserve  | Moves Hadia's earned commission to its own paybill, till or bank account automatically.                                                                      |

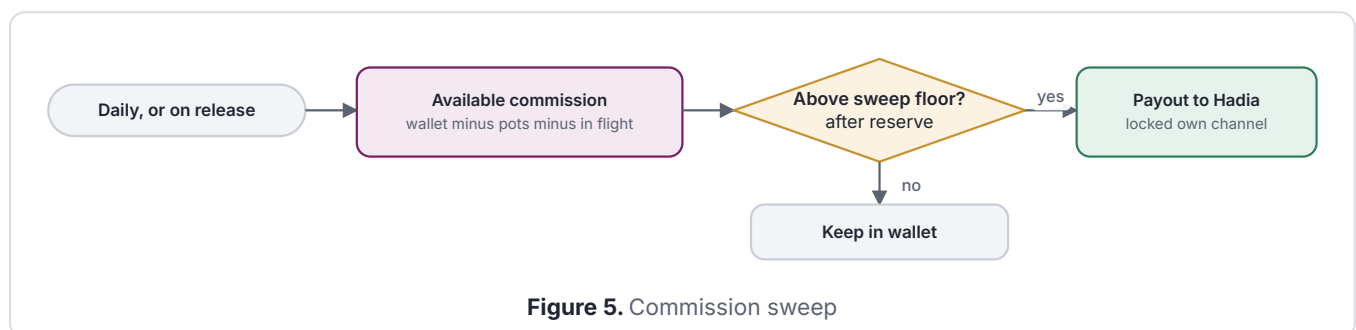
## Automatic payout, end to end



Every safeguard in the figure already exists in treasury today: a payout is claimed under a reference unique to the attempt (ESC-code-1, ESC-code-2 and so on) before PayHero is called, only one release can be in flight per pot, a refused or failed payout returns the money to the pot, and a payout whose callback never arrives is looked up with PayHero after 15 minutes. Callbacks are treated as hints; treasury confirms each result with PayHero before booking it.

## Hadia's fee: deducted, retained, then swept

At each payout the commission is subtracted from the gross and the owner receives the net. The commission stays in Hadia's PayHero wallet and is booked as income in account 4800. A new scheduled sweep moves it out:



1. The sweep runs daily (and can also run right after a payout, if Hadia prefers).

2. It works out what is free to move: the PayHero wallet balance, less the total of all pot balances, less releases in flight, less a reserve Hadia keeps for PayHero costs. The hourly reconciliation already computes this figure.
3. If the free amount is above the sweep floor, treasury pays it to Hadia's own channel through the same payout dispatcher. The destination is locked to one of Hadia's verified channels and changing it needs MFA and resets verification.
4. The books record the transfer from the PayHero wallet account to Hadia's bank or paybill account. If the reconciliation shows a shortfall, the sweep does not run and finance is alerted.

Hadia can also choose to retain commission in the wallet and withdraw it by hand, which treasury already supports.

## **Reconciliation**

Every hour treasury compares the sum of all pot balances plus payouts in flight with the PayHero wallet balance. The surplus is Hadia's commission and other wallet money less PayHero's costs. A shortfall is logged as an error, raised in the exception queue and blocks the commission sweep until it is explained. Each pot also has its own statement (contributions, payouts, returns) that can be downloaded as PDF, CSV or Excel.

## 10. Critical workflows, step by step

Each workflow lists the trigger, the steps, what is automated and what happens when something goes wrong. Steps marked **AUTO** need no person. The low-fidelity screens below show the three moments that matter most; final visuals follow Hadia's mock-up.

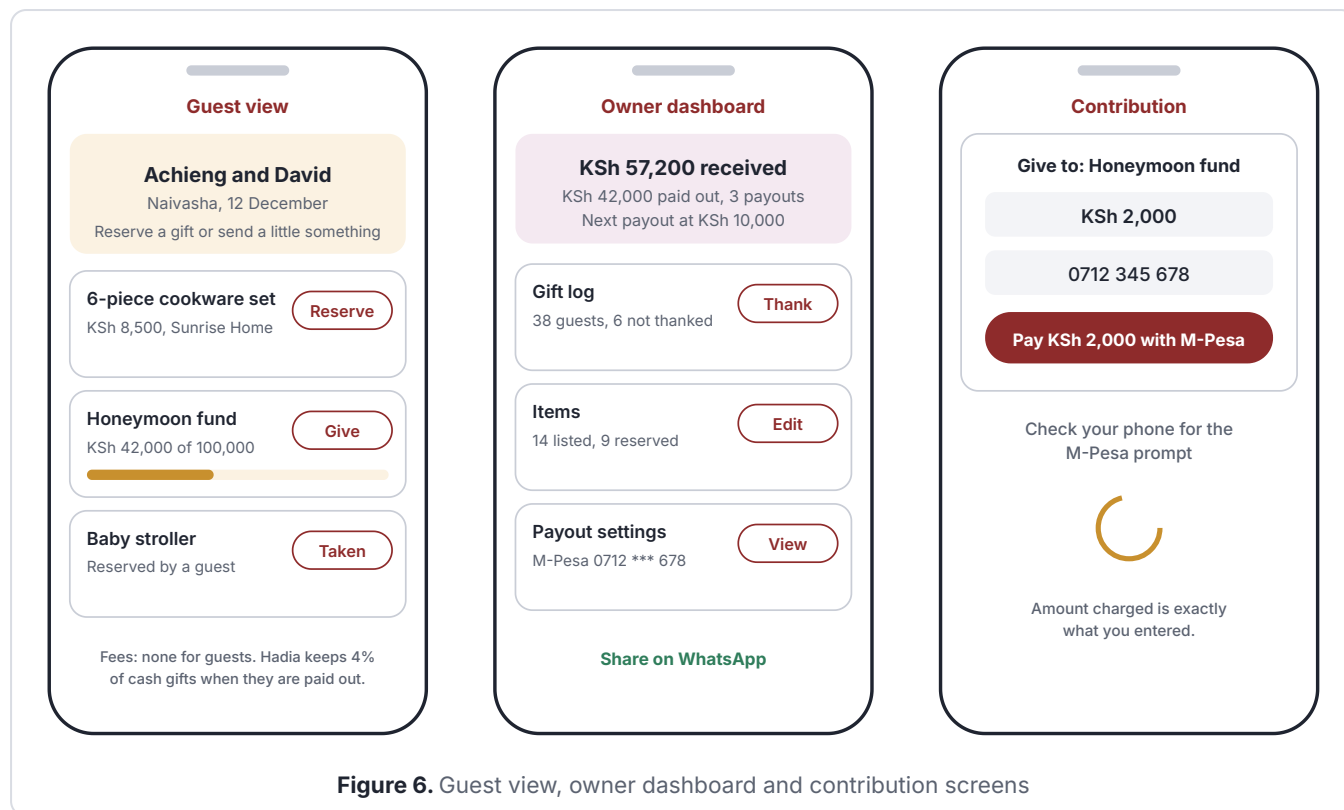


Figure 6. Guest view, owner dashboard and contribution screens

### W1. Hadia business onboarding (once)

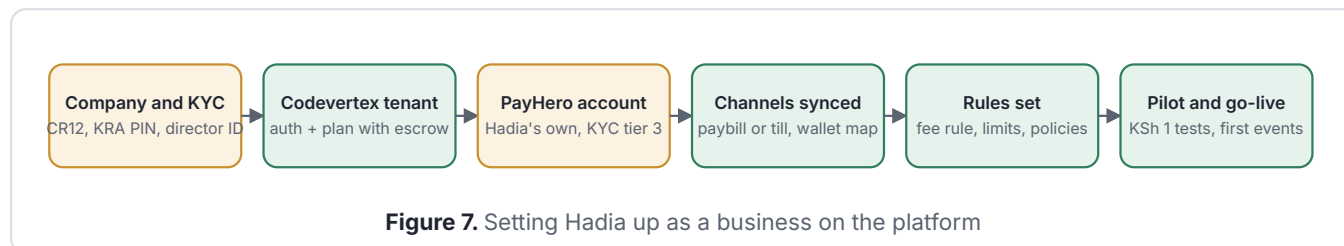
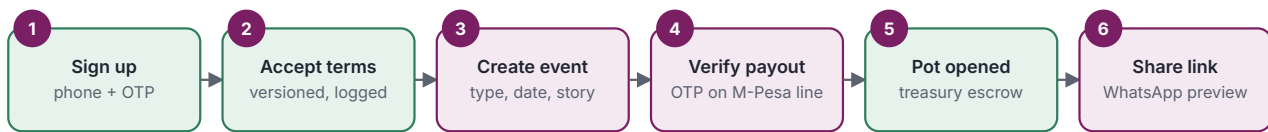


Figure 7. Setting Hadia up as a business on the platform

1. Hadia provides company documents (certificate of incorporation, CR12, KRA PIN, director ID, bank or paybill details).
2. Codevertex creates the Hadia tenant in auth-api and the plan with the escrow and M-Pesa features in subscriptions-api.
3. Hadia's PayHero Team is created or linked to the tenant. Hadia completes PayHero KYC to tier 3 (national ID plus company KRA PIN), which PayHero requires before a Team wallet can collect from the public.
4. Hadia's paybill or till is added as a channel and synced; the Team wallet and channels are mapped to accounts in Hadia's chart of accounts.
5. Hadia accepts the escrow terms in treasury (Hadia holds its customers' money for their beneficiaries and is responsible for releasing it).
6. Hadia sets the commission rule, payout policy and approval limit, contribution limits and sweep schedule.
7. Live KSh 1 tests: a contribution, a payout, a refund and a sweep, each reconciled, before the first real event.

## W2. Registry owner onboarding



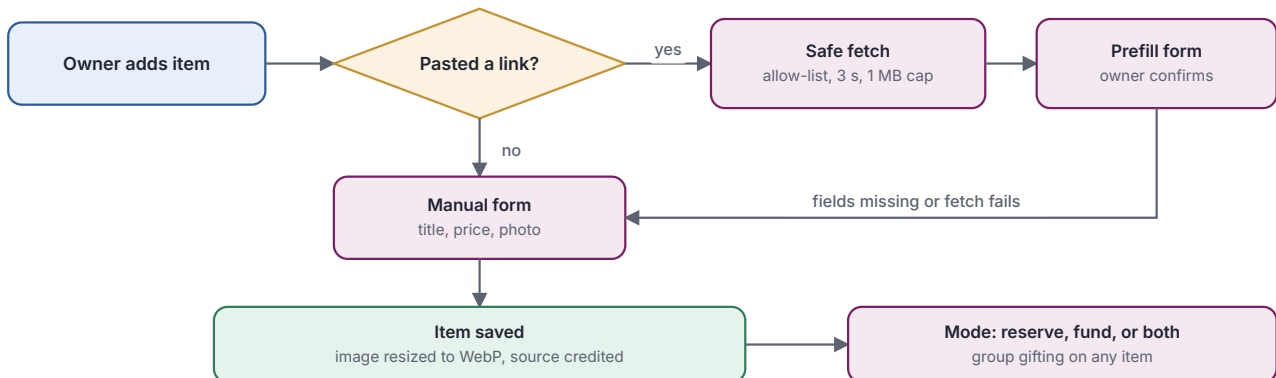
Time to a live, shareable registry: under five minutes. Steps in green reuse existing services.

**Figure 8.** From sign-up to a shared registry

1. The owner enters a phone number. auth-api sends a 6-digit code by SMS (WhatsApp if SMS fails) **AUTO**. Codes are hashed, expire in 5 minutes, and sending is capped per phone and per IP.
2. The owner confirms age 18 or above and accepts the terms and privacy notice. auth-api stores the version and time.
3. The owner creates the event: type, title, date, optional place, cover photo, short story.
4. The owner confirms the payout M-Pesa number with an OTP sent to it. This proves control of the line that will receive money.
5. hadia-api asks treasury to open the escrow pot with the owner as beneficiary and Hadia's default rules **AUTO**.
6. The registry gets its short link and preview image, and the owner shares it on WhatsApp.

**When it goes wrong:** if the pot cannot be opened (for example PayHero is unavailable), the registry is saved as a draft and the pot request is retried by a background job; the owner can keep adding items while it waits.

## W3. Listing items



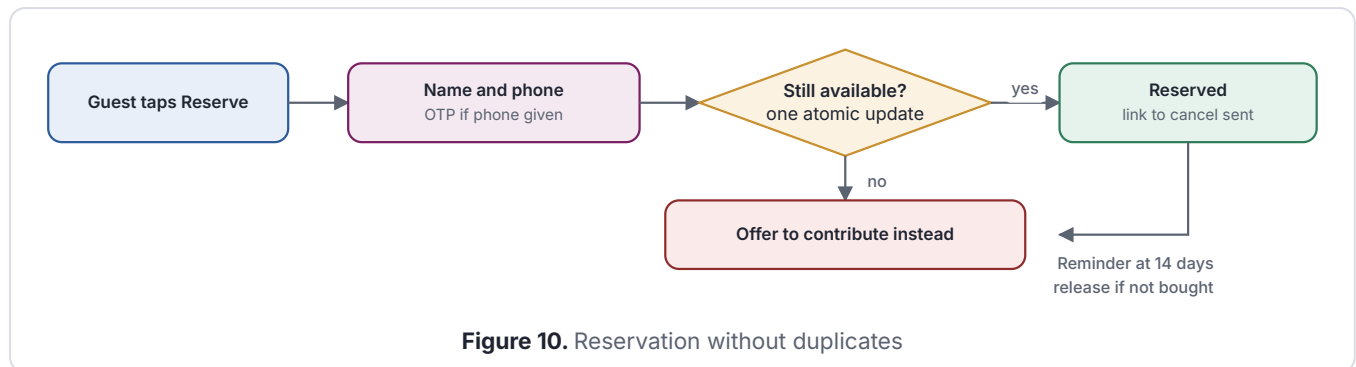
**Figure 9.** Adding an item by link or by hand

1. The owner pastes a link or taps "Add by hand".
2. For a link, hadia-api fetches the page server-side with strict limits: public internet addresses only (private and internal ranges refused, the same rule treasury uses for webhooks), 3 second timeout, 1 MB size cap, no cookies. It reads Open Graph and product schema tags for title, image and price.
3. The form is prefilled and the owner confirms or edits. If nothing useful was found, the form simply stays empty for typing.
4. Photos are resized and converted to WebP (640 px and 1280 px versions), stored in object storage, and served through the CDN. The source shop is shown as "from Shop name" with a link.
5. The owner chooses the mode: reserve, fund, or both (group gifting).

## W4. Sharing

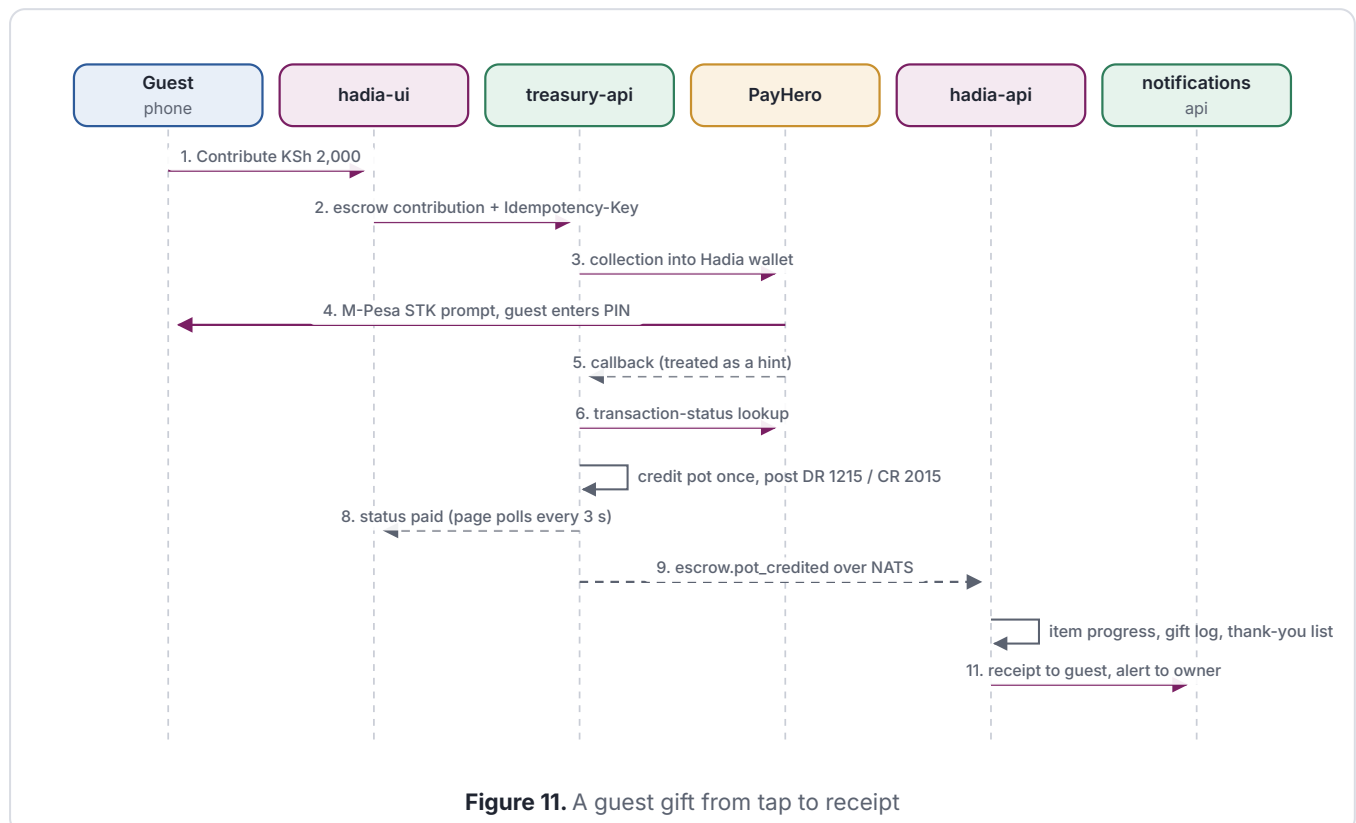
1. Each registry has a short link, for example [hadia.co.ke/r/achieng-david](https://hadia.co.ke/r/achieng-david) (premium) or [hadia.co.ke/r/K7Q2M9](https://hadia.co.ke/r/K7Q2M9) (standard).
2. A preview image is rendered per registry (cover photo, names, date) at 1200 by 630 pixels and kept under 300 KB, so WhatsApp shows it reliably **AUTO**.
3. The share sheet offers WhatsApp, SMS, copy link and a QR code for printed cards.

## W5. Reserving an item



1. The guest taps Reserve, enters a name and, optionally, a phone number to manage the reservation.
2. hadia-api reserves with one conditional update (only if units remain). If two guests tap at the same moment, exactly one wins; the other is told the item was just taken and offered to contribute instead.
3. The guest receives a link to cancel. The owner sees the reservation, and other guests see the item as taken.
4. After 14 days without "bought", the guest and owner are reminded; the owner may release the item **AUTO**.

## W6. Contributing money



1. The guest picks an item or fund, enters an amount and phone number. Limits are checked before anything is sent.

2. hadia-ui calls treasury's public escrow contribution endpoint with an idempotency key, so a double tap or a retry can never charge twice.
3. Treasury starts a PayHero collection into Hadia's wallet; the guest gets the M-Pesa prompt and enters the PIN.
4. PayHero calls back. Treasury looks the payment up with PayHero before trusting it, then credits the pot once and posts the accounting entry **AUTO**.
5. The checkout page, which polls every 3 seconds, shows success. Treasury publishes escrow.pot\_credited.
6. hadia-api updates the item's progress and the gift log, and asks notifications-api to send the guest a receipt and the owner an alert **AUTO**.

**When it goes wrong:** a prompt that fails or is cancelled leaves the gift pending and offers the paybill route. Treasury's prompt guard stops repeated prompts to one phone (5 failures in 24 hours) to protect guests from spam prompts. A callback that never arrives is resolved by a status lookup.

## W7. Managing the pot

1. The owner sees received, paid out, pending and next payout on the dashboard; numbers come from treasury and the gift log.
2. The owner can change the target, the threshold (within Hadia's limits) and the event date. The payout number can be changed only with a fresh OTP on the new number and never while a payout is in flight.
3. Items funded beyond their price show as fully funded; extra money stays in the pot and is paid out with the rest.
4. After the event, the registry stays open for late gifts for the hold window, then closes to new gifts. The owner can reopen it.

## W8. Automatic payouts

Described in full in chapter 9 and Figure 4. In short: every 5 minutes, pots whose threshold is reached or whose event hold has passed are paid out to the verified number, less commission, with approval only above Hadia's limit **AUTO**. The owner receives an SMS with the gross, the fee and the net.

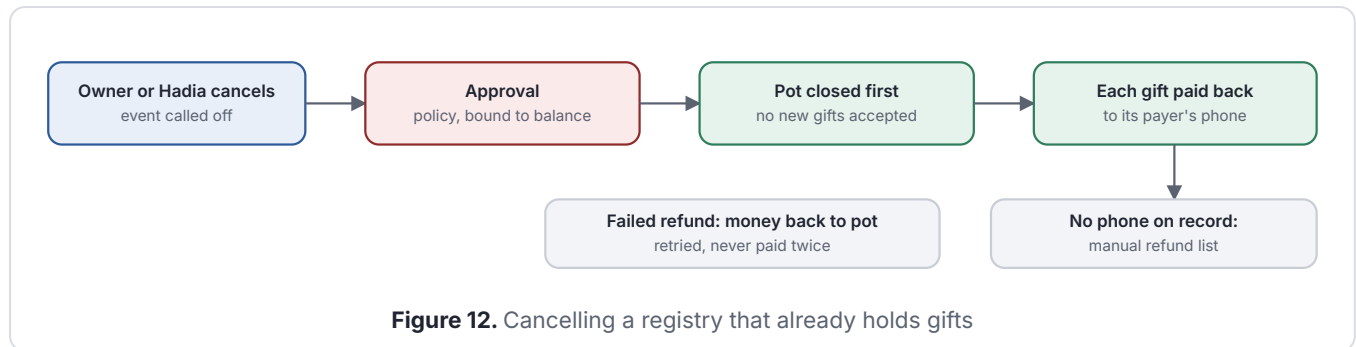
## W9. Commission and sweep

Described in chapter 9 and Figure 5. Commission is deducted at each payout, booked as Hadia's income, and swept daily to Hadia's own account above the floor **AUTO**. An eTIMS-compliant invoice for Hadia's fee is available to the owner on request through treasury's existing eTIMS integration.

## W10. Premium upgrade

1. The owner taps Upgrade on an event and sees exactly what premium adds and the price.
2. hadia-api creates a payment intent in treasury (an ordinary sale for Hadia, not escrow) and opens the shared payment modal.
3. On confirmation treasury books the sale as Hadia's revenue and publishes payment.succeeded; hadia-api switches on the features: custom link, printable list, instant payouts (pot threshold set to pay every gift) **AUTO**.
4. A receipt is sent. Refunds of premium follow the refund policy.

## W11. Cancellation and refunds



1. The owner asks to cancel (for example, the event is called off), or Hadia cancels after a fraud or policy finding.
2. The refund passes the approval policy, bound to the pot and its balance.
3. The pot is closed first so no new gifts arrive, then each gift is paid back to the phone it came from, each with its own reference **AUTO**.
4. A failed refund returns the money to the pot for retry. A repeated cancel never pays anyone twice. Gifts with no phone on record are listed for Hadia to settle by hand.

## W12. Exceptions and reconciliation

1. Hourly reconciliation runs per tenant **AUTO**.
2. Exceptions go to one queue in the Hadia admin: failed payouts after retry, M-Pesa name mismatches, refunds needing manual action, reconciliation shortfalls, reported registries, approval requests.
3. Each item shows the facts, the suggested action and who handled it. Finance gets a daily summary by email or WhatsApp.

## W13. Thank-you tracker

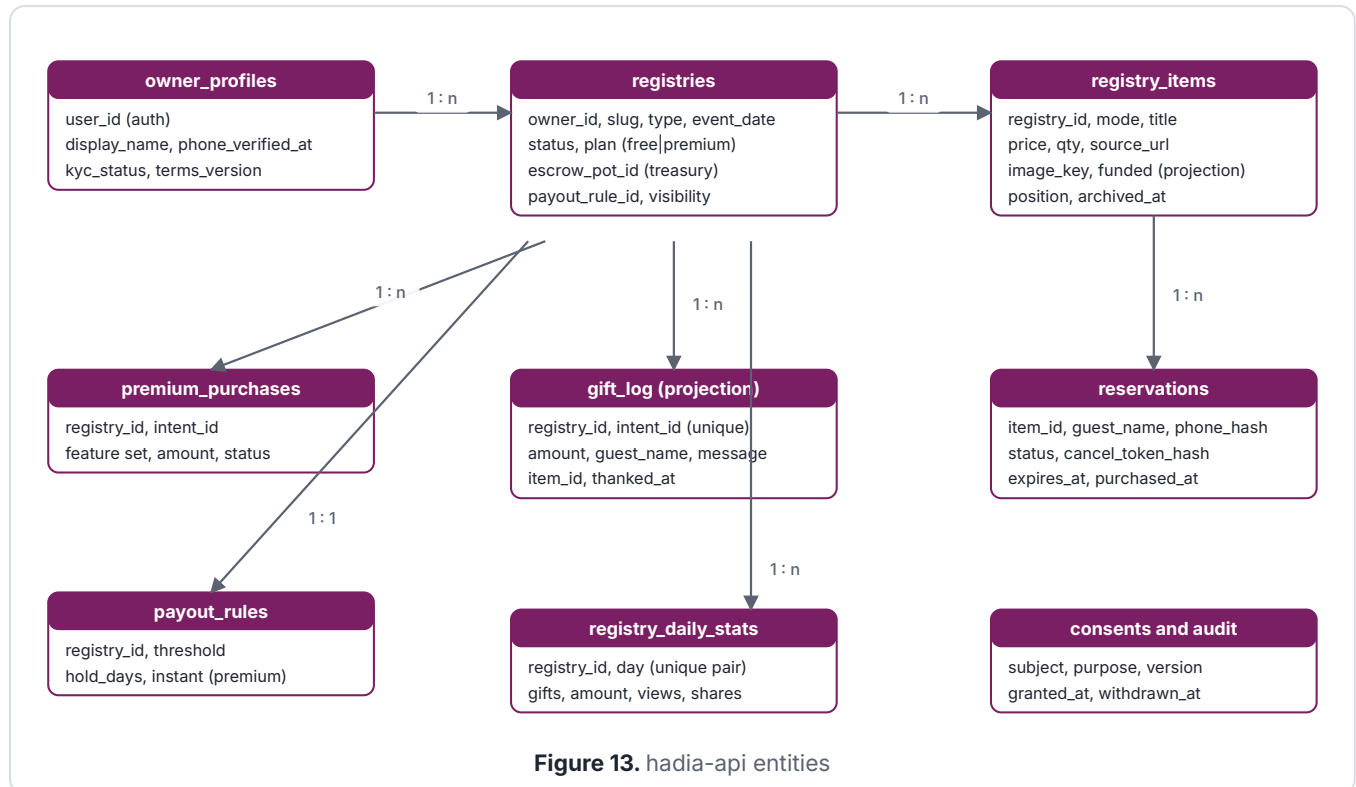
1. Every gift and reservation appears in the gift log with the guest's message.
2. The owner taps Thank to open WhatsApp with a prepared message to that guest, then marks it thanked.
3. A gentle reminder lists unthanked guests a week after the event (owner can switch it off).

## W14. Data requests and account deletion

1. An owner or guest asks for a copy of their data, a correction or deletion, from the privacy page or by email.
2. Identity is confirmed by OTP. The request is logged with its legal deadline.
3. Export: a machine-readable file of profile, registries, items, reservations and gifts.
4. Deletion: personal data is erased or anonymised. Financial records required by tax law (contributions, payouts, invoices) are kept for the statutory period with the person's name replaced by a reference, and the person is told what was kept and why.

## 11. Data design

hadia-api owns the registry domain. It holds references to other services' records by ID only: the owner's user ID from auth-api and the pot ID and payment intent IDs from treasury.



### Choices that keep it fast as data grows

- Every table has the tenant ID and the indexes its queries need, created by versioned Atlas migrations reviewed like code.
- Lists use keyset pagination (the shared pagination package), never deep offsets, so page 500 is as fast as page 1.
- The gift log is unique on the payment intent ID, so a redelivered event cannot create a second row.
- Counters such as an item's funded amount are updated with arithmetic in SQL in the same statement, never read then written.
- Reports read from registry\_daily\_stats, a rollup updated as events arrive, not from raw gifts.
- Guest phone numbers are stored hashed where only matching is needed (reservations) and encrypted where they must be read (receipts), with keys outside the database.
- Photos live in object storage; the database stores keys only.

## 12. Interfaces, events and notifications

### hadia-api endpoints (summary)

| Area       | Endpoints                                                                                                         | Access               |
|------------|-------------------------------------------------------------------------------------------------------------------|----------------------|
| Registries | GET, POST /registries; GET, PATCH /registries/{id}; POST /registries/{id}/publish, /close, /cancel                | Owner                |
| Items      | GET, POST /registries/{id}/items; PATCH, DELETE /items/{id}; POST /items/preview (link fill); POST /items/reorder | Owner                |
| Public     | GET /r/{code}; POST /r/{code}/items/{item}/reserve; POST /reservations/{token}/cancel                             | Anyone, rate limited |
| Gifts      | GET /registries/{id}/gifts; POST /gifts/{id}/thanked; GET /registries/{id}/statement                              | Owner                |
| Premium    | POST /registries/{id}/premium (returns the checkout intent)                                                       | Owner                |
| Privacy    | POST /privacy/export, /privacy/delete; GET /privacy/requests                                                      | Owner, guest by OTP  |
| Admin      | Search, moderation, exceptions, settings, reports                                                                 | Hadia staff by role  |

### Treasury endpoints used (already built)

| Purpose                             | Endpoint                                                                       |
|-------------------------------------|--------------------------------------------------------------------------------|
| Open, read, update a pot            | POST, GET, PUT /{tenant}/escrow/pots                                           |
| Guest contribution                  | POST /api/v1/pay/{tenant}/escrow/{code}/contributions                          |
| Public pot view                     | GET /api/v1/pay/{tenant}/escrow/{code}                                         |
| Release, cancel with refunds        | POST /{tenant}/escrow/pots/{pot}/release, /cancel?refund=true                  |
| Commission rule, readiness, summary | GET, PUT /{tenant}/escrow/fee-rule; GET /escrow/readiness; GET /escrow/summary |
| Statements                          | GET /{tenant}/escrow/pots/{pot}/statement and /statement/document              |
| Premium sale                        | POST /{tenant}/payments/intents, then the shared pay page or payment modal     |

### Events

| Event                                               | From      | hadia-api reaction                                                           |
|-----------------------------------------------------|-----------|------------------------------------------------------------------------------|
| escrow.pot_created                                  | treasury  | Mark the registry's pot as ready, publish the registry                       |
| escrow.pot_credited                                 | treasury  | Add to gift log, update item funding and daily stats, send receipt and alert |
| escrow.dispatched                                   | treasury  | Record payout, send the owner gross, fee and net                             |
| escrow.dispatch_failed                              | treasury  | Exception queue, owner told the payout will retry                            |
| escrow.cancelled                                    | treasury  | Close registry, tell guests their gifts are being returned                   |
| payment.succeeded (premium)                         | treasury  | Switch on premium features                                                   |
| hadia.registry_published, hadia.reservation_created | hadia-api | Consumed by notifications and analytics                                      |

Consumers are idempotent (claim on event ID before acting). If NATS is unavailable, treasury's outbox holds events until it returns; treasury's signed tenant webhooks are available as a second channel for any future external integration.

## Messages

| Message                                  | To                  | Channel                                                 |
|------------------------------------------|---------------------|---------------------------------------------------------|
| Sign-in code                             | Owner, guest        | SMS, WhatsApp fallback                                  |
| Gift receipt                             | Guest               | SMS or WhatsApp                                         |
| New gift, new reservation                | Owner               | WhatsApp or SMS, daily digest option                    |
| Payout made, payout delayed              | Owner               | SMS                                                     |
| Reservation reminder, thank-you reminder | Guest, owner        | WhatsApp or SMS                                         |
| Refund made                              | Guest               | SMS                                                     |
| Exception summary, approval needed       | Hadia finance       | Email, WhatsApp                                         |
| Product news and tips                    | Owners who opted in | Email or WhatsApp, with an unsubscribe in every message |

## 13. Reports and analytics built for growth

The brief asks for reports that stay correct and fast as Hadia grows. We applied that to the services Hadia depends on and fixed what we found before writing this proposal (Appendix A lists the changes).

| Report                                                      | For            | Source and method                                                                    |
|-------------------------------------------------------------|----------------|--------------------------------------------------------------------------------------|
| Registry dashboard                                          | Owner          | Treasury pot balance and released totals, hadia-api gift log by keyset page          |
| Gifts and value by day, week, month                         | Hadia          | registry_daily_stats rollup, one row per registry per day                            |
| Active events, new registries, conversion from view to gift | Hadia          | Daily stats plus page-view counters aggregated in Redis and flushed every minute     |
| Commission earned, premium sales                            | Hadia finance  | Treasury books: account 4800 and premium revenue, trial balance and income statement |
| Funds held, in flight, surplus                              | Hadia finance  | Treasury escrow summary, now summed in the database by tenant                        |
| Payout speed and failures                                   | Hadia ops      | Payout records: time from rule met to confirmed, failure reasons                     |
| Pot statement                                               | Owner, finance | Treasury statement document (PDF, CSV, Excel)                                        |

Heavy, read-only reports can use the platform's read replica, and repeated dashboard reads are cached for 60 seconds with invalidation on the matching event, so a busy weekend of gifts does not slow down the guest pages.

## 14. Security design

| Threat                                        | Control                                                                                                                                                                                                                                |
|-----------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Account takeover                              | OTP rate limits per phone and IP, hashed codes, short expiry, session revocation, MFA for all staff, re-verification for payout changes                                                                                                |
| Payout fraud<br>(changing where money goes)   | Payout number verified by OTP on that line, change blocked while a payout is in flight, approvals bound to amount and destination, name check on first payout, alerts on change                                                        |
| Double charging or double paying              | Idempotency keys on contributions, unique references per payout attempt, single settlement path, status lookups instead of trusting callbacks                                                                                          |
| Fake registries and scams                     | Moderation queue, report button on every registry, velocity limits on new pots, cap on pot balance, hold before first payout for new owners                                                                                            |
| Money laundering                              | Contribution and balance limits, KYC on Hadia (tier 3) and verified owner lines, monitoring for unusual patterns (many large gifts from few phones, rapid open and close), suspicious activity escalated to Hadia's compliance officer |
| Server-side request forgery through link fill | Public addresses only, DNS checked after resolution, no redirects to private ranges, time and size caps                                                                                                                                |
| Injection and cross-site scripting            | Parameterised queries (Ent), output encoding, strict Content Security Policy, sanitised rich text                                                                                                                                      |
| Bots and abuse                                | Rate limits on public endpoints, prompt guard on STK pushes, Cloudflare WAF in front of all hosts                                                                                                                                      |
| Data exposure                                 | TLS everywhere, encryption at rest for backups and sensitive fields, least-privilege roles, payout details never shown on public pages, audit log of staff access                                                                      |
| Card data                                     | Card payments run on the provider's hosted checkout, so card numbers never touch Hadia's servers                                                                                                                                       |

## 15. Legal, regulatory and compliance

**Please read this first.** This chapter maps the laws we know apply to an online gifting and payments business in Kenya and shows how the design meets them. It is a technical compliance plan, not legal advice. Before launch, Hadia's own Kenyan advocate should review the legal pack and confirm the points marked "confirm". Building these protections in from the first sprint is far cheaper than retrofitting them after a complaint.

### Who is responsible for what

| Party                     | Legal role                                                                                                                      | Main duties                                                                                                                                              |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Hadia                     | Business operating the service; data controller; holds its customers' money for their beneficiaries through its PayHero account | Terms with users, fees, payouts, complaints, registration with the Data Commissioner, tax on its income, KYC and AML cooperation                         |
| Codevertex Africa Limited | Software provider and data processor for Hadia                                                                                  | Build and run the software securely, process data only on Hadia's instructions under a data processing agreement, report breaches to Hadia without delay |
| PayHero                   | Payment service provider                                                                                                        | Collections, wallet, payouts, its own KYC and AML duties, card handling on hosted checkout                                                               |
| Messaging providers       | Sub-processors (Africa's Talking, WhatsApp, Brevio)                                                                             | Deliver messages under their terms; listed in the privacy notice                                                                                         |

### Laws that apply and how the platform meets them

| Law                                                                                                                                                         | What it requires of Hadia                                                                                                                                                                                                                                                                                                                               | How Hadia meets it                                                                                                                                                                                                                                                                    |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Constitution of Kenya, Article 31, and the Data Protection Act, 2019, with the Data Protection (General) Regulations, 2021 and the registration regulations | Lawful, minimal, transparent processing; registration with the Office of the Data Protection Commissioner (ODPC); data protection impact assessment for high-risk processing; data subject rights; breach notice to the ODPC within 72 hours; safeguards for cross-border transfers; consent for direct marketing; parental consent for children's data | Privacy notice, consent records, minimal data, DPIA drafted in weeks 2 to 6, registration of Hadia as controller (Codevertex as processor), data request workflow with deadlines (W14), breach runbook, documented hosting location and transfer safeguards, marketing only on opt-in |
| Consumer Protection Act, 2012                                                                                                                               | No false, misleading or unconscionable representations; for internet agreements, clear disclosure before the customer agrees, an express chance to accept or decline and correct errors, and a copy of the agreement                                                                                                                                    | Fees and payout timing shown before sign-up and before every payment, clickwrap acceptance with the version logged, terms emailed or downloadable, honest marketing copy (see the mock-up review below)                                                                               |
| Competition Act, 2010                                                                                                                                       | No false or misleading claims about the service, including reviews and testimonials                                                                                                                                                                                                                                                                     | Only real, consented testimonials; no invented counts; claims backed by evidence held on file                                                                                                                                                                                         |

|                                                                                        |                                                                                                                               |                                                                                                                                                                                                                                                                                   |
|----------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| National Payment System Act, 2011, and its regulations                                 | Payment services and holding money for others are regulated by the Central Bank of Kenya                                      | All money is collected, held and paid out by PayHero in Hadia's account; holding periods are short and capped; per-pot ledgers and hourly reconciliation. <b>Confirm</b> with Hadia's advocate whether Hadia needs its own CBK authorisation or written guidance as volumes grow. |
| Proceeds of Crime and Anti-Money Laundering Act, 2009                                  | Prevent the service being used to launder money; keep records; cooperate with reporting institutions                          | KYC tier 3 on Hadia, verified payout lines, contribution and balance caps, pattern monitoring, records kept for the statutory period, a named compliance contact at Hadia                                                                                                         |
| Computer Misuse and Cybercrimes Act, 2018                                              | Protect systems and data; handle unlawful content and incidents                                                               | Security controls in chapter 14, audit logs, moderation and reporting tools, incident response plan                                                                                                                                                                               |
| Kenya Information and Communications Act and the Consumer Protection Regulations, 2010 | Electronic records and signatures are valid; no unsolicited commercial messages; an easy opt-out                              | Logged clickwrap acceptance; transactional messages only unless opted in; STOP and unsubscribe in every marketing message; sender ID registered through the SMS provider                                                                                                          |
| Tax Procedures Act, 2015, VAT Act, 2013 and the eTIMS rules                            | Keep records for at least five years; issue electronic tax invoices for business income; register for VAT above the threshold | Hadia's books in treasury, gifts held as a liability (never Hadia's revenue), commission and premium booked as income, eTIMS invoices through treasury's existing KRA integration. <b>Confirm</b> VAT and any excise duty treatment of Hadia's fee with a tax adviser.            |
| Children Act, 2022 and section 33 of the Data Protection Act                           | Children's data only with parental consent and in the child's best interests                                                  | Owners must be 18 or older; baby registries ask the parent to confirm consent before adding a child's name or photo; guidance and defaults avoid a child's full name on public pages; registries are unlisted by default                                                          |
| Persons with Disabilities Act and Article 54 of the Constitution                       | Services offered to the public should be accessible                                                                           | WCAG 2.2 AA built and tested (NFR-08)                                                                                                                                                                                                                                             |
| Copyright Act, 2001 and Trade Marks Act                                                | Respect owners of images, text, fonts and marks                                                                               | Licensed fonts and images only; shop photos shown as linked thumbnails with credit and removed on request; shop names used only to describe where an item is from, no shop logos without permission                                                                               |
| Business Registration Service Act and company law                                      | Trade under the registered name and show who the business is                                                                  | Registered name, number, address and contacts in the footer of every page and every receipt                                                                                                                                                                                       |

|                                                                         |                                                                                     |                                                                                                                                                           |
|-------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Foreign rules for diaspora users: EU and UK GDPR, US CAN-SPAM and COPPA | Similar privacy rights; unsubscribe in emails; no collection from children under 13 | The Kenyan controls above meet the core of these; cookie consent before any optional cookie; unsubscribe in every email; service not directed at children |
|-------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|

## The 20-point "don't get sued" checklist

Hadia shared a 20-item checklist for keeping an app out of legal trouble. Every item is covered below, with the law behind it and what we deliver.

| #  | Item                   | What Hadia gets                                                                                                                                                                                                                                          | Delivered by                                      |
|----|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------|
| 1  | Privacy policy         | Plain-language privacy notice naming Hadia as controller, Codevertex and providers as processors, purposes, lawful bases, retention, rights, transfers and contacts. Linked from every page, form and message footer.                                    | Draft by Codevertex, sign-off by Hadia's advocate |
| 2  | Terms of service       | Owner terms, guest terms, escrow and payout terms, acceptable use, fees, liability limits, dispute process, governing law of Kenya. Clickwrap with versioning; changes notified 14 days ahead.                                                           | Draft by Codevertex, sign-off by advocate         |
| 3  | Refund policy          | When gifts are returned (cancelled event, mistaken payment, fraud), timelines, premium refund within 14 days if unused, how fees are treated. The refund flow (W11) enforces it.                                                                         | Built in, policy text by Hadia                    |
| 4  | Cookie policy          | Lists every cookie by category with purpose and lifetime. Only strictly necessary cookies at launch.                                                                                                                                                     | Built in using the shared legal pages             |
| 5  | Cookie consent banner  | The shared Codevertex cookie notice: nothing optional pre-selected, "Reject optional" and "Accept all" equally prominent, settings reopenable from the footer.                                                                                           | Reused (shared-ui-lib)                            |
| 6  | Check form consents    | Every form states why each field is asked; separate, unticked checkboxes for terms, marketing and child data; consent stored with version and time; withdrawal as easy as giving it.                                                                     | Built in                                          |
| 7  | No unnecessary data    | Guests give only a name and phone for gifts; no ID numbers, no dates of birth, no location tracking; owner KYC limited to the payout line; data map reviewed in the DPIA.                                                                                | Built in                                          |
| 8  | Audit third-party SDKs | No ad trackers or social pixels at launch. A register of every third party (PayHero, Africa's Talking, WhatsApp, Brevo, Cloudflare, Google sign-in if enabled) with the data each receives; analytics only after consent and self-hosted where possible. | Built in, register in the handover pack           |
| 9  | Remove dark patterns   | No pre-ticked boxes, no fake urgency or scarcity, no confirm-shaming, cancel premium and delete account in as few steps as sign-up, honest progress bars.                                                                                                | Built in, checked in UX review                    |
| 10 | Remove hidden fees     | Guests pay exactly what they enter. Owners see the commission and payout schedule before creating a registry and on every payout SMS and statement. Premium price shown before checkout.                                                                 | Built in                                          |
| 11 | Remove fake reviews    | The mock-up's testimonial and "400+ families" figure are removed until real. Testimonials published only with written consent and kept on file.                                                                                                          | Content change, see below                         |

|    |                            |                                                                                                                                                                                                                      |                                                       |
|----|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------|
| 12 | Remove unsupported claims  | Claims such as "funds go straight to you" and "your money, kept safe" rewritten to describe exactly how money is held and when it is paid.                                                                           | Content change, see below                             |
| 13 | Accessibility alt text     | Alt text required for owner-uploaded photos (suggested from the item title), meaningful alt on all site images, decorative images hidden from screen readers.                                                        | Built in                                              |
| 14 | Fix colour contrast        | Brand palette checked to 4.5:1 for text and 3:1 for controls; the mock-up's light gold and grey text adjusted where it fails.                                                                                        | Built in                                              |
| 15 | Keyboard navigation        | Every action reachable by keyboard, visible focus, logical order, dialogs that trap and return focus, skip-to-content link; automated axe checks in CI plus manual testing.                                          | Built in                                              |
| 16 | Add business details       | Registered name, registration number, KRA PIN (optional), physical address, email and phone in the footer and on receipts, using the shared LegalLinks component, which now accepts a tenant's own business details. | Reused and extended                                   |
| 17 | Age consent for kids' data | Owners confirm 18 or above; parental confirmation before any child's name or photo; defaults that keep children off public pages.                                                                                    | Built in                                              |
| 18 | Unsubscribe link in emails | One-click unsubscribe in every marketing email and STOP in every marketing SMS or WhatsApp; preferences page; transactional messages kept separate.                                                                  | Reused (notifications-api preferences)                |
| 19 | License fonts and images   | Open-licence fonts (SIL OFL) and owned or licensed photos only; a licence register in the handover pack; the mock-up's illustrations redrawn or licensed.                                                            | Built in, register by Codevertex                      |
| 20 | Data deletion request      | Self-service export and deletion with OTP, deadlines tracked, financial records kept anonymised for the tax retention period with an explanation to the person (W14).                                                | Built in, reusing the platform's data request pattern |

## Mock-up review: changes before launch

| Mock-up text                                                         | Risk                                                           | Suggested replacement                                                                                        |
|----------------------------------------------------------------------|----------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| "Loved by 400+ families"                                             | Unverified figure; misleading representation                   | Remove at launch. Add a real count once it is true and can be shown from data.                               |
| Testimonial from "Achieng and David, married in Naivasha, June 2026" | Appears to be a placeholder; a fake review                     | Replace with real pilot testimonials collected with written consent, or remove.                              |
| "Funds go straight to you" and "I land straight with you"            | Inaccurate: funds are held, then paid out by rules, less a fee | "Cash gifts are held safely and paid to your M-Pesa automatically, less Hadia's 4% fee. You choose when."    |
| "Your money, kept safe"                                              | Unsupported without explanation                                | Keep with a link to a short page explaining PayHero, separate records per registry and daily reconciliation. |
| "Free to create ... You only ever share in what's actually given"    | Must match the premium offer and fee                           | "Free to create. Hadia keeps 4% of cash gifts. Optional premium for KSh 300 per event."                      |
| "Add things from Carrefour, Naivas, TikTok Shop"                     | Use of third-party marks                                       | Acceptable as plain text describing where items can come from; do not use their logos or imply partnership.  |

## Records and retention

| Record                                               | Kept for                                                                           | Reason                                 |
|------------------------------------------------------|------------------------------------------------------------------------------------|----------------------------------------|
| Contributions, payouts, refunds, invoices, books     | At least 5 years after the transaction (7 recommended)                             | Tax Procedures Act, AML record keeping |
| Owner account and registries                         | Until deletion is requested, or 24 months after the last activity, then anonymised | Data minimisation                      |
| Guest name and phone on reservations without payment | 12 months after the event                                                          | Managing reservations and thank-yous   |
| OTP codes                                            | 5 minutes, stored hashed                                                           | Security                               |
| Consent and terms acceptance                         | Life of the account plus 5 years                                                   | Proof of consent and agreement         |
| Security and audit logs                              | 12 months online, longer in archive if an incident is open                         | Investigation and accountability       |

## Legal pack in the handover

- Privacy notice, cookie policy, terms of service (owners and guests), refund policy, acceptable use policy.
- Data processing agreement between Hadia and Codevertex, and the sub-processor list.
- Data protection impact assessment and the record of processing activities.
- Breach response and incident runbook, data request procedure.
- Third-party and licence register, accessibility statement, marketing claims evidence file.

## 16. Delivery methodology

We deliver in short Agile sprints with a working demo every week, so Hadia sees real progress early and can change direction while it is cheap to do so.

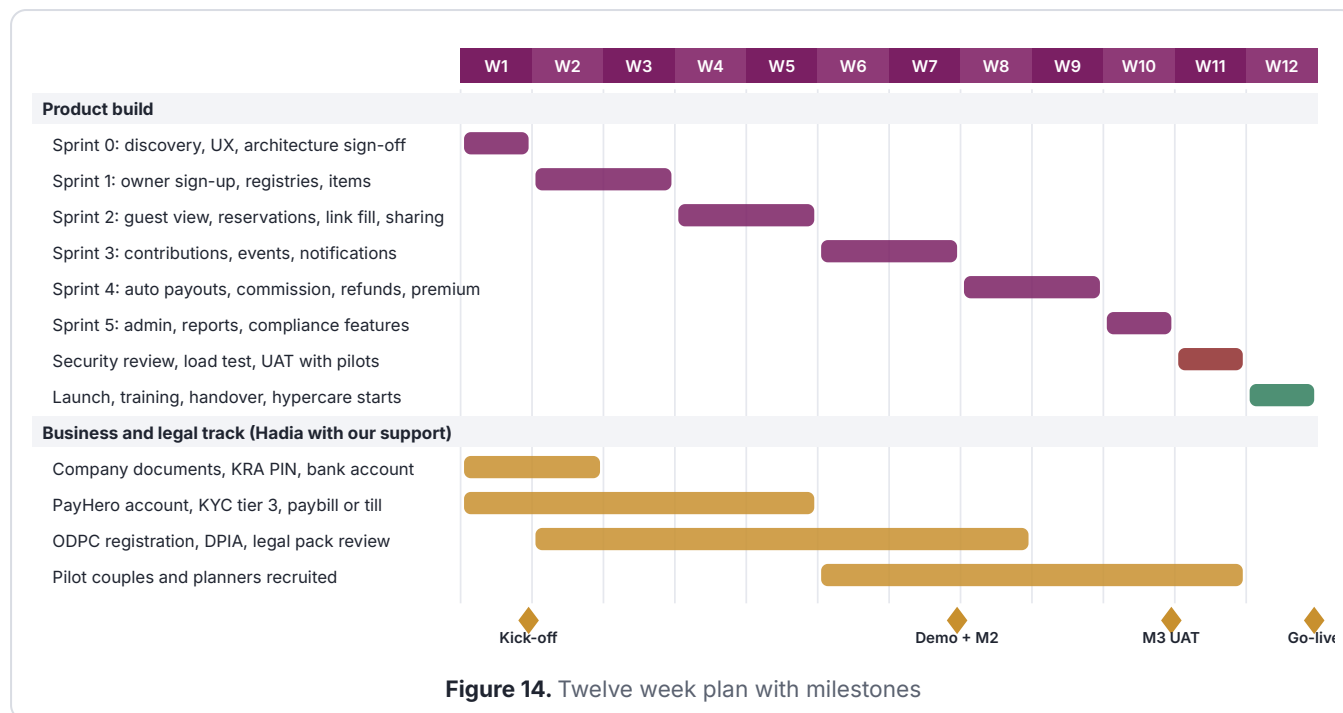
| Practice           | How it works on this project                                                                                                                                                                            |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Sprints            | A one-week Sprint 0, four two-week sprints, a one-week Sprint 5, then a test week and a launch week.                                                                                                    |
| Weekly demo        | Every Friday, a 30 minute call with Tracey on the staging site. Decisions recorded in the shared backlog.                                                                                               |
| Backlog            | User stories traced to the FR and NFR IDs in this document, each with acceptance criteria written before work starts.                                                                                   |
| Definition of done | Code reviewed, automated tests passing, accessibility checks passing, documented, deployed to staging, accepted by the product owner.                                                                   |
| Environments       | Development, staging and production on the Codevertex cluster. Staging uses provider sandboxes where they exist and live KSh 1 tests where they do not.                                                 |
| Quality            | Unit and database tests for each service, end-to-end browser tests for the guest and owner journeys, contract tests on the treasury and auth calls, load test before launch.                            |
| Release            | GitHub Actions builds and tests every change; ArgoCD deploys from Git, so every release is traceable and reversible.                                                                                    |
| Reporting          | A short written status each Friday: done, next, risks, decisions needed.                                                                                                                                |
| Change control     | New ideas go to the backlog. Within the fixed price, Hadia may swap a requirement for one of similar size. Larger changes are estimated in time and cost first, and only proceed with written approval. |

### Team

| Role                                  | Allocation                                              |
|---------------------------------------|---------------------------------------------------------|
| Project lead and business analyst     | Part time, all 12 weeks                                 |
| Full-stack engineers (Go and Next.js) | Two, weeks 1 to 12                                      |
| Product designer                      | Part time, weeks 1 to 5 and reviews after               |
| QA engineer                           | Part time, weeks 3 to 12                                |
| Platform and DevOps engineer          | Shared, as needed for environments, security and launch |

## 17. Implementation timeline

The plan fits in exactly twelve weeks. The business and legal track runs alongside the build from day one, because PayHero onboarding and Data Commissioner registration depend on Hadia's documents rather than on code.



| Weeks  | Sprint            | Deliverables                                                                                                                                                                   |
|--------|-------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1      | Sprint 0          | Kick-off, confirmed backlog, UX flows and visual design from the mock-up, architecture sign-off, environments, accessibility palette check, legal pack outline                 |
| 2 to 3 | Sprint 1          | Phone OTP sign-in for consumers in auth-api, owner onboarding, registries and items by hand, photo pipeline, owner dashboard shell, Hadia tenant set up                        |
| 4 to 5 | Sprint 2          | Guest registry page, atomic reservations, link auto-fill, share previews and QR codes, escrow pot creation, payout number verification                                         |
| 6 to 7 | Sprint 3          | Contributions through treasury checkout, escrow event consumer, gift log, receipts and alerts, statements. <b>Milestone 2:</b> end-to-end demo with a live KSh 1 gift          |
| 8 to 9 | Sprint 4          | Automatic payout rules, commission rule, commission sweep, contribution limits, approvals above the limit, cancellation and refunds, premium upgrade                           |
| 10     | Sprint 5          | Hadia admin console, exception queue, reports and rollups, consent and data request flows, cookie notice, accessibility pass. <b>Milestone 3:</b> feature complete, UAT starts |
| 11     | Hardening and UAT | Security review, load test, user acceptance testing with 3 to 5 pilot couples and planners, fixes, legal pack signed off by Hadia's advocate                                   |
| 12     | Launch            | Production go-live, staff training, runbooks and handover pack, hypercare begins. <b>Milestone 4:</b> launch accepted                                                          |

If Hadia signs by Friday 16 October 2026, week 1 starts Monday 19 October and launch falls in the week of 4 January 2027, ready for the year's wedding season. Public holidays on 25 and 26 December and 1 January are already allowed for.

## 18. Testing and acceptance

| Test                | What it proves                                                         | Exit criteria                                                                  |
|---------------------|------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| Automated tests     | Business rules and money paths behave as specified                     | All passing on every merge; money paths covered by database-backed tests       |
| End-to-end journeys | Owner sign-up to payout, guest reserve and contribute, refund, premium | All journeys pass on staging on Android Chrome, iPhone Safari and desktop      |
| Live money tests    | Real M-Pesa collection, payout, refund and sweep                       | KSh 1 tests reconcile to the cent with PayHero and the books                   |
| Load test           | Peak Saturday traffic                                                  | 2,000 gifts an hour and 50 guest page views a second with NFR-02 met           |
| Security review     | OWASP top risks, auth, payout changes, link fetching                   | No open high or critical findings                                              |
| Accessibility       | WCAG 2.2 AA                                                            | Automated checks clean, manual keyboard and screen reader pass on key journeys |
| UAT                 | Hadia and pilot users agree it works for them                          | All "must" requirements accepted; no open severity 1 or 2 defects              |

## 19. Commercials

### Build price

The fixed price for the scope in this document is **USD 4,750**, inclusive of all taxes, within the USD 1,500 to 5,000 range in Hadia's brief. It can be invoiced in Kenya shillings at the Central Bank of Kenya rate on the invoice date.

| Work package                                                                                                 | USD          |
|--------------------------------------------------------------------------------------------------------------|--------------|
| Discovery, UX and visual design, architecture                                                                | 450          |
| Registry service (hadia-api): registries, items, reservations, link fill, gift log, statistics               | 1,050        |
| Web app (hadia-ui): landing site, guest pages, owner dashboard, admin console                                | 1,100        |
| Money integration: escrow pots, contributions, automatic payouts, commission sweep, limits, refunds, premium | 900          |
| Phone OTP sign-in, messaging templates and preferences                                                       | 350          |
| Compliance features and legal pack drafts, accessibility                                                     | 400          |
| Testing, security review, UAT support, launch and handover                                                   | 500          |
| <b>Total fixed price</b>                                                                                     | <b>4,750</b> |

### Payment schedule

| Milestone                           | When           | Share | USD   |
|-------------------------------------|----------------|-------|-------|
| M1 Signing                          | Week 0         | 30%   | 1,425 |
| M2 End-to-end demo with a live gift | End of week 7  | 30%   | 1,425 |
| M3 Feature complete, UAT starts     | End of week 10 | 30%   | 1,425 |
| M4 Launch accepted                  | End of week 12 | 10%   | 475   |

### Monthly running costs

These follow the brief's estimate of USD 100 to 200 a month and are paid by Hadia to the providers or to Codevertex as applicable.

| Item                                                                                                                              | USD a month             |
|-----------------------------------------------------------------------------------------------------------------------------------|-------------------------|
| Hosting, database, storage, backups and the Codevertex platform services Hadia uses (sign-in, books and escrow, messaging engine) | 20 to 50                |
| Payment costs not covered by commission: PayHero service wallet top-ups, paybill or till upkeep, payout costs                     | 50 to 100               |
| SMS and WhatsApp messages at launch volumes                                                                                       | 15 to 40                |
| <b>Estimated total</b>                                                                                                            | <b>about 100 to 200</b> |

Message and payment costs rise with use, and so does commission. Domain names, Hadia's advocate's fees and marketing are not included.

## **Why it pays for itself**

Using the brief's own illustration, 100 active events a month with an average of USD 200 in cash gifts each gives about USD 800 in commission at 4%, plus about USD 100 to 150 in premium upgrades, roughly USD 900 to 950 a month against USD 100 to 200 in running costs. These figures are illustrative, not a forecast.

## 20. Risks and mitigations

| Risk                                                           | Impact                   | Mitigation                                                                                                                                                                              | Owner             |
|----------------------------------------------------------------|--------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------|
| PayHero onboarding or KYC takes longer than five weeks         | No live money for pilots | Start in week 1; Codevertex helps with the Team set-up; build and test with KSh 1 transactions as soon as the account is live; launch can begin with reservations-only events if needed | Hadia, Codevertex |
| Regulatory view that Hadia needs its own payment authorisation | Delay or change of model | Advocate opinion in weeks 2 to 6; short holds and caps; money always with the licensed provider; option to pay out every gift instantly, which minimises holding                        | Hadia             |
| Fraudulent registries used to collect money                    | Losses, reputation       | Verified payout lines, limits, first-payout hold for new owners, monitoring, report button, moderation                                                                                  | Hadia ops         |
| Payout failures on M-Pesa                                      | Owner frustration        | Automatic return to pot and retry, status lookups, clear SMS to the owner, exception queue                                                                                              | Codevertex        |
| Link auto-fill fails on local shops                            | Slower item entry        | Manual entry is the main path and is fast; auto-fill improves over time                                                                                                                 | Codevertex        |
| Scope growth during the build                                  | Timeline slip            | Change control; swaps of equal size; out-of-scope list agreed up front                                                                                                                  | Both              |
| Festive season availability                                    | Slower decisions         | Holidays already in the plan; decisions batched at the Friday demo                                                                                                                      | Both              |
| Low adoption of cash gifting                                   | Revenue below plan       | Pilot with planners and church networks as the brief suggests; analytics on conversion from week 12                                                                                     | Hadia             |

## 21. Assumptions, dependencies and client responsibilities

---

- Hadia is, or will be by week 2, a registered Kenyan company with a KRA PIN and a bank account or paybill in its name.
- Hadia completes PayHero KYC promptly and supplies documents within 3 working days of a request.
- Hadia appoints one product owner who can make decisions within 2 working days.
- Hadia provides brand assets, final copy (Codevertex drafts first versions) and real testimonials when available.
- Hadia engages a Kenyan advocate to review the legal pack and the payment regulation question.
- Hadia recruits 3 to 5 pilot events for week 11.
- Hadia subscribes to the Codevertex plan that includes escrow and M-Pesa integration; this is part of the running costs above.
- The domain name (for example hadia.co.ke) is registered by Hadia.

## 22. Support after launch

---

- **Hypercare:** 30 days of close monitoring after launch, with same-day response to payment issues.
- **Warranty:** defects against this specification fixed at no cost for 90 days after launch.
- **Monitoring:** alerts on failed payouts, reconciliation differences, error spikes and slow pages, routed to Codevertex on-call and Hadia's ops contact.
- **Ongoing support and new features** (for example native apps, Kiswahili, planner referral codes) can be agreed separately when Hadia is ready.
- **Handover pack:** admin guide, finance guide, runbooks, legal pack, licence and third-party registers, architecture notes.

## 23. Acceptance and sign-off

By signing, both parties accept this document as the agreed scope, plan and price for the Hadia build. Changes follow the change control process in chapter 16.

| Hadia     | Codevertex Africa Limited |
|-----------|---------------------------|
| Name      |                           |
| Title     |                           |
| Signature |                           |
| Date      |                           |

## Appendix A: ecosystem audit findings

Before writing this proposal we audited the Codevertex services Hadia will rely on, so the plan reuses what exists, avoids duplicate logic, and does not inherit problems that would appear as Hadia grows.

### Already fixed during the audit

| Service             | Finding                                                                                                             | Change                                                                                                                                              |
|---------------------|---------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| treasury-api-escrow | The 5-minute payout job read every auto-release pot into memory and checked each wallet balance with its own query. | The job now reads only pots that can pay out now (rule can fire, money in the wallet), in pages of 200, with balances loaded in one query per page. |
| treasury-api-escrow | Escrow totals for the dashboard and the hourly reconciliation loaded every pot and wallet.                          | Totals are summed in the database, grouped by tenant; only pots with a payout in flight are read.                                                   |
| treasury-api-escrow | A refund result scanned all of a tenant's cancelled pots to find its own.                                           | The pot is found directly from the code in the refund reference.                                                                                    |
| treasury-api-escrow | Payout results looked up the pot by its in-flight reference without an index.                                       | New partial index on the in-flight reference, with a versioned migration.                                                                           |
| shared-ui-lib       | The legal footer always showed Codevertex's business details.                                                       | LegalLinks accepts the tenant's own business details (version 0.1.102), which Hadia's footer uses.                                                  |

### Built as part of this project

- auth-api: passwordless phone OTP sign-in for consumers (today OTP is available only to signed-in users).
- treasury-api: scheduled commission sweep with a locked, verified destination; per-pot minimum and maximum contribution.
- notifications-api: Hadia message templates and sender ID.
- hadia-api: consumer for treasury's escrow events.

### Noted for the platform team

- The PayHero guide says escrow can run on a tenant's own PayHero account, while the escrow readiness check requires a Team account. Hadia's plan uses a Team, and the guide will be aligned.
- Creating PayHero Teams by API needs PayHero's enterprise plan on the platform organisation; until then a Team created by PayHero is linked to the tenant. This is on Hadia's onboarding track.

## Appendix B: glossary

| Term              | Meaning                                                              |
|-------------------|----------------------------------------------------------------------|
| Registry          | An owner's list of wanted items and funds for one event              |
| Pot               | The escrow record in treasury that holds a registry's cash gifts     |
| Release or payout | Paying a pot's balance, less commission, to the owner                |
| Commission        | Hadia's percentage fee on cash gifts, taken at payout                |
| Sweep             | Automatic transfer of earned commission to Hadia's own account       |
| STK push          | The M-Pesa prompt on the payer's phone asking for a PIN              |
| PayHero Team      | Hadia's own account at PayHero, with an isolated wallet              |
| KYC               | Know your customer: identity checks required by payment providers    |
| ODPC              | Office of the Data Protection Commissioner, Kenya's data regulator   |
| DPIA              | Data protection impact assessment                                    |
| eTIMS             | KRA's electronic tax invoice management system                       |
| PWA               | Progressive web app: a website that installs and behaves like an app |
| WCAG              | Web Content Accessibility Guidelines                                 |
| Idempotency key   | A unique key that makes a repeated request act only once             |

Codevertex Africa Limited, Pioneer House, Kisumu, Kenya. [info@codevertexafrica.com](mailto:info@codevertexafrica.com). [www.codevertexafrica.com](http://www.codevertexafrica.com)